M2 STRI
Projet Traitements Répartis

INFRASTRUCTURE A CLES PUBLIQUES

Contexte de l'application à réaliser

On souhaite avoir une messagerie simplifiée entre utilisateurs d'une organisation (entreprise, administration…). Cette messagerie sera sécurisée au moyen d'une Infrastructure à Clés Publiques.
La cryptographie à clé publique (CP ou PK – Public Key) est utilisée comme mécanisme support au chiffrement de messages, à l'authentification d'entités ou encore à la signature numérique de messages.
La confiance est un élément fondamental dans l'usage de la cryptographie à clé publique : l'utilisateur d'une CP doit être sûr de l'identité de son propriétaire. Les infrastructures à clés publiques (ICP ou PKI – Public Key Infrastructure) visent à renforcer cette certitude. Elles sont bâties autour de la notion de certificat : un certificat contient à la fois la CP ainsi que l'information permettant l'identification du propriétaire de la paire (clé publique, clé privée). L'information contenue dans un certificat doit être vérifiée et signée par une autorité de confiance dénommée habituellement autorité de certification (AC ou CA – Certification Authority). D'autre part, l'usage d'une biclé a une portée précise (signature et/ou chiffrement et/ou non répudiation…).

Ainsi, pour utiliser une CP en toute sécurité, un utilisateur doit pouvoir répondre avec certitude à un certain nombre de questions parmi lesquelles :
- « à qui appartient cette CP ? »
- « à quoi sert cette CP ? »

On supposera l'existence de cinq types de composants d'une ICP :
- les ACs qui ont la confiance d'un ou plusieurs utilisateurs pour éditer et révoquer les certificats. Elles maintiennent localement les certificats valides et la liste de ceux révoqués (LCR). Elles peuvent aussi offrir un service de publication qui rend disponibles les certificats et créer des biclés.
- les AEs (Autorités d'Enregistrement) qui, optionnellement, se portent garantes du lien entre une CP et l'identité du porteur.
- les porteurs de certificats qui peuvent signer et/ou déchiffrer les documents. Un porteur est le seul à disposer de la clé privée associée à la CP mentionnée dans le certificat.
- les utilisateurs qui vérifient les signatures ou chiffrent et valident la certification à partir d'une AC digne de confiance. Il convient de vérifier l'intégrité, la validité et la politique d'usage du certificat.
- les AVs (Autorités de Validation) qui, sur sollicitation des précédents, donnent le statut courant d'un certificat (valide, révoqué, inconnu).

On envisage alors quelques scénarii classiques spécifiés ci-après sous forme de processus :

Processus de création de certificat :

1. un porteur fait une demande de certification auprès d'une AE. Il y indique son identité, l'usage escompté, et la CP.
2. L'AE procède à l'authentification et à la vérification des droits du demandeur

   On supposera pour simplifier qu'une AE dispose d'entrées de la forme : nom_entité, mot_de_passe, droit_signature (oui/non), droit_chiffrement (oui/non), droit_de_demande_de_révocation (oui/non).
3. La demande est ensuite transmise à l'AC qui peut générer le certificat.
4. L'AC demande sa publication.
5. L'AC transmet le certificat à l'AE qui, à son tour, le relaye au demandeur.

Processus de révocation de certificat :

1. Un porteur demande à rendre un certificat non valide, définitivement (révocation) ou temporairement (suspension) avant sa date de fin de validité.
2. L'AE procède à l'authentification et à la vérification des droits de révocation du demandeur.
3. La demande est ensuite transmise à l'AC qui peut enregistrer la révocation du certificat.
4. L'AC demande la publication de la révocation dans la LCR.

Processus de validation des certificats :

1. Contrôle de la période de validité.
2. Vérification de la signature du certificat et analyse du chemin de certification.
3. Contrôle de l'état du certificat auprès de l'AV.
4. Contrôle de la politique d'usage du certificat.

Processus d'utilisation :

Dans le cadre de l'utilisation d'une telle infrastructure, on souhaite qu'une messagerie texte soit développée. Cette messagerie permettra l'échange de messages "non sécurisés" ou "signés" ou "chiffrés" ou "signés et chiffrés".

1. Lors de la préparation du premier message d'un échange, le choix du niveau de sécurité de l'échange sera laissé à l'utilisateur initiant l'échange. Le reste de l'échange conservera les modalités choisies au début de l'échange.
2. Le fonctionnement suivant est alors proche d'un "chat".
3. L'échange prend fin lorsqu'un des correspondants inscrit uniquement le code FIN_MSG dans un message.

Noyau de l'application à réaliser

Nous proposons de développer une ICP simplifiée destinée à être déployée au sein d'une unique organisation et s'adressant à des ressources d'un même domaine de confiance.
En particulier, on supposera que les certificats manipulés ici mentionnent :

- Un numéro de série unique dans le domaine de confiance,
- Un identifiant de l'AC qui a édité et signé ce certificat,
- Une période de validité du certificat (deux dates),
- L'usage de la clé,
- L'identité du propriétaire (ou sujet),
- La CP,
- La signature de l'AC.

Contraintes de déploiement

On envisage la possibilité de mise en œuvre d'une hiérarchie d'AC sur trois niveaux au moins. (On rappelle que dans une architecture hiérarchique de PKI, qu'il existe une AC racine (niveau 1) qui est « implicitement » de confiance et qui auto signe son propre certificat. Elle peut émettre des certificats pour d'autres ACs dites « filles » (ou intermédiaires) qui à leur tour pourront émettre des certificats pour des ACs subordonnées ou pour des porteurs finals. Chaque utilisateur peut alors à partir d'un certificat « utilisateur » construire le chemin de confiance en remontant des ACs filles signataires jusqu'à l'AC racine.

On souhaite être capable de facilement déployer la solution développée en calquant l'architecture hiérarchique sur le découpage fonctionnel d'une organisation. Par exemple pouvoir disposer d'une AC pour chaque direction définie dans une entreprise (niveau 2), puis d'autant d'AC filles des précédentes (niveau 3) par Direction que nécessaire.

D'autre part, selon sa nature, une ressource (humaine, matérielle, logicielle…) pourra s'adresser au plus bas niveau à une AE qui gère les demandes de certification propres à cette nature (Par exemple, il existera une AE pour les routeurs, une autre pour les logiciels de messagerie…). Il en sera de même pour les AVs.

Organisation du projet et travail attendu

Établir un dossier de conception de l'application permettant de répondre aux spécifications précédemment énoncées. Ce dossier de conception devra au moins comporter :

- Une vue fonctionnelle du système distribué (on pourra s'appuyer sur des diagrammes de cas d'utilisation UML) :
- Les différentes entités logicielles reparties en identifiant leur rôle (on pourra s'appuyer sur un diagramme de composants et/ou de déploiement UML).
- Les interactions pouvant survenir entre ces types d'entités (diagrammes de séquence UML).
- Vos choix argumentés sur l'utilisation de telle technologie de répartition sur telle partie du système.
- L'architecture JMS du système réparti (clients JMS et destinations : files / sujets), ainsi que la spécification des messages échangés (nom du message, propriétés éventuelles, type et contenu).
- La description des ressources et du schéma de nommage pour les services REST (une documentation standardisée OpenAPI devra être fournie).
- Les micro-services « edge » qui vous paraissent utiles pour cette architecture.